

1. Arborescence de l'Annuaire (Active Directory)

La gestion des identités du groupe Ymmo est centralisée sur les contrôleurs de domaine du siège social via le domaine racine `ymmo.local`. Afin d'appliquer les Stratégies de Groupes (GPO) de manière granulaire et de déléguer l'administration si nécessaire, l'arborescence des Unités Organisationnelles (OU) est structurée par localisation puis par service métier.

Structure AD DS recommandée :

```
DC=ymmo,DC=local
├── OU=YMMO_SIEGE
│   ├── OU=Direction (Utilisateurs, Ordinateurs, Groupes Locaux)
│   ├── OU=Commercial_Siege
│   ├── OU=Marketing_Com
│   ├── OU=Admin_RH_Juridique
│   └── OU=IT_Support
└── OU=YMMO_AGENCES
    ├── OU=Agence_1 (Utilisateurs Nomades, Ordinateurs Agence)
    ├── ...
    └── OU=Agence_12
```

2. Stratégies de Groupe (GPO)

Des GPO spécifiques seront créées et liées aux différentes OU pour automatiser l'environnement utilisateur et renforcer la sécurité sur les postes de travail :

- **GPO_Lecteurs_Reseau** : Mappage dynamique du lecteur S : \ pointant vers le serveur de fichiers (`\10.0.10.11\Partages_Ymmo`). L'affichage des dossiers est filtré via la fonctionnalité *Access-Based Enumeration (ABE)* pour que les utilisateurs ne voient que les dossiers auxquels ils ont accès.
- **GPO_Seurite_Globale** : Liée à la racine du domaine, elle impose le verrouillage de session après 15 minutes d'inactivité, la désactivation de l'invite de commande (CMD) pour les non-administrateurs, et bloque le stockage amovible USB.
- **GPO_Mots_De_Passe** : Politique de mot de passe stricte appliquée via un *Fine-Grained Password Policy (FGPP)* : 12 caractères minimum, complexité obligatoire, et verrouillage du compte après 5 tentatives échouées.

3. Matrice des Droits NTFS (Serveur de Fichiers)

L'implémentation des permissions respecte scrupuleusement la règle **AGDLP** (Accounts -> Global Groups -> Domain Local Groups -> Permissions). Les utilisateurs sont placés dans des Groupes Globaux métiers, eux-mêmes membres de Groupes Locaux de Domaine liés aux permissions NTFS locales du serveur de fichiers.

Dossier Racine partagé	Direction	Commercial	Com & Marketing	Administratif (RH)	IT & Support
\Direction	Lecture / Écriture	Interdit	Interdit	Interdit	Interdit
\Commercial	Lecture Seule	Lecture / Écriture	Lecture Seule	Lecture Seule	Lecture Seule
\Communication	Lecture Seule	Lecture Seule	Lecture / Écriture	Lecture Seule	Lecture Seule
\Administratif	Lecture Seule	Interdit	Interdit	Lecture / Écriture	Interdit
\Support_IT	Lecture Seule	Interdit	Interdit	Interdit	Lecture / Écriture

1. Segmentation Réseau et Pare-feu (Firewall)

La première ligne de défense de l'infrastructure Ymmo s'appuie sur une segmentation logique poussée via la mise en place de VLANs sur le site principal. Ces VLANs sont routés exclusivement par le pare-feu matériel central (FortiGate 100F).

Modèle Zero-Trust (Implicitement refusé) : La règle par défaut au bas de la liste de contrôle d'accès (ACL) du pare-feu est un DENY ALL. Seuls les flux explicitement déclarés sont autorisés.

- **Isolation des serveurs :** Le VLAN 10 (Serveurs) n'a pas accès à Internet directement. Les mises à jour s'effectuent via un proxy ou un serveur WSUS dédié. Les requêtes entrantes vers les serveurs sont scannées par un moteur IPS (Intrusion Prevention System).
- **Filtrage Web (UTM) :** Sur les VLANs utilisateurs et agences distantes, un filtrage DNS et URL est actif pour bloquer l'accès aux sites malveillants, non productifs ou illégaux.
- **Protection de la messagerie :** Tous les flux SMTP/IMAP sont scannés par un moteur antivirus de flux pour éviter l'ingestion de malwares ou de ransomwares.

2. Politique de Mise à Jour (Patch Management)

Pour garantir la remédiation rapide des failles de sécurité (CVE) :

- Déploiement du rôle **WSUS (Windows Server Update Services)** sur le réseau du siège.
- Les postes clients et serveurs téléchargent leurs mises à jour depuis ce point central via une configuration poussée par GPO.
- **Rythme :** Mises à jour de sécurité critiques approuvées et poussées sous 48h. Mises à jour fonctionnelles testées sur un panel restreint de machines avant déploiement général chaque mois (Patch Tuesday).

3. Audit et Logs

L'activation des logs de sécurité est obligatoire sur les contrôleurs de domaine (via GPO : "Auditer les événements de connexion au compte" et "Auditer l'accès aux objets"). Les logs du pare-feu sont conservés pendant 1 an sur un stockage distinct pour garantir la traçabilité en cas d'incident ou de comportement suspect sur le VPN des agences.

1. Plan de Sauvegarde (Règle du 3-2-1)

Afin d'assurer la survie numérique de l'entreprise Ymmo face à un sinistre (incendie du siège, vol, ou attaque de ransomware), le plan de sauvegarde s'appuie sur le standard de l'industrie : **la règle du 3-2-1**, pilotée par la solution Veeam Backup & Replication.

Déclinaison de la règle 3-2-1 pour Ymmo :

- **3** copies des données critiques : Les données de production en direct, une sauvegarde primaire et une sauvegarde secondaire.
- **2** supports de stockage différents : Un NAS/Serveur de stockage dédié situé dans une salle physique différente au siège (sauvegardes rapides), et du stockage Objet.
- **1** copie hors-site (Cloud) : Externalisation automatisée quotidienne.

Supervision des sauvegardes : Des alertes e-mails automatiques sont configurées pour notifier le pôle IT en cas d'échec ou de non-lancement d'un Job de sauvegarde. Un test de restauration (Restore Test) d'une VM critique ou d'un partage de fichier est planifié mensuellement pour garantir l'intégrité des archives.

2. Déploiement d'une Solution Cloud Hybride (Cible Azure / AWS)

Pour répondre à l'exigence d'évolution et de scalabilité, Ymmo amorce une transition vers le Cloud Hybride. L'objectif n'est pas de tout déporter sur le Cloud, mais d'utiliser les services publics (IaaS/PaaS) pour pallier les limites de l'infrastructure locale.

2.1 Synchronisation des Identités avec Microsoft Azure

Le domaine local ymmo.local est connecté à un locataire **Azure AD (Microsoft Entra ID)** via l'outil Azure AD Connect.

- **Avantage 1 (MFA)** : Permet d'imposer l'Authentification Multifacteur pour l'accès aux ressources critiques depuis l'extérieur (très utile pour les commerciaux en déplacement).
- **Avantage 2 (SSO)** : Single Sign-On pour les futurs outils SaaS (CRM, ERP), réduisant le nombre de mots de passe à mémoriser pour les collaborateurs.

2.2 Sauvegarde Cloud Immuable sur AWS S3

La copie hors-site (le "1" de la règle 3-2-1) est hébergée sur **Amazon Web Services (AWS)** au sein d'un bucket S3. La fonctionnalité critique activée ici est l'**Object Lock (mode de conformité WORM)**.

Pendant la durée de rétention définie (ex: 30 jours), il est techniquement impossible de supprimer, chiffrer ou modifier les fichiers de sauvegarde stockés sur AWS, et ce, même si un attaquant parvient à récupérer les clés d'API administrateur de l'entreprise. C'est la protection ultime contre les ransomwares modernes.

2.3 Scalabilité du Stockage Fichiers (Azure File Sync)

Si la volumétrie des fichiers des pôles administratifs et commerciaux devient trop importante pour le serveur local, le déploiement d'**Azure File Sync** est proposé. Le serveur local ne conserve en cache rapide que les fichiers les plus récemment utilisés (Tiering), tandis que les données froides sont stockées de manière

transparente sur Azure Files, libérant ainsi de l'espace disque physique au siège social tout en garantissant l'accès permanent aux agences distantes.